



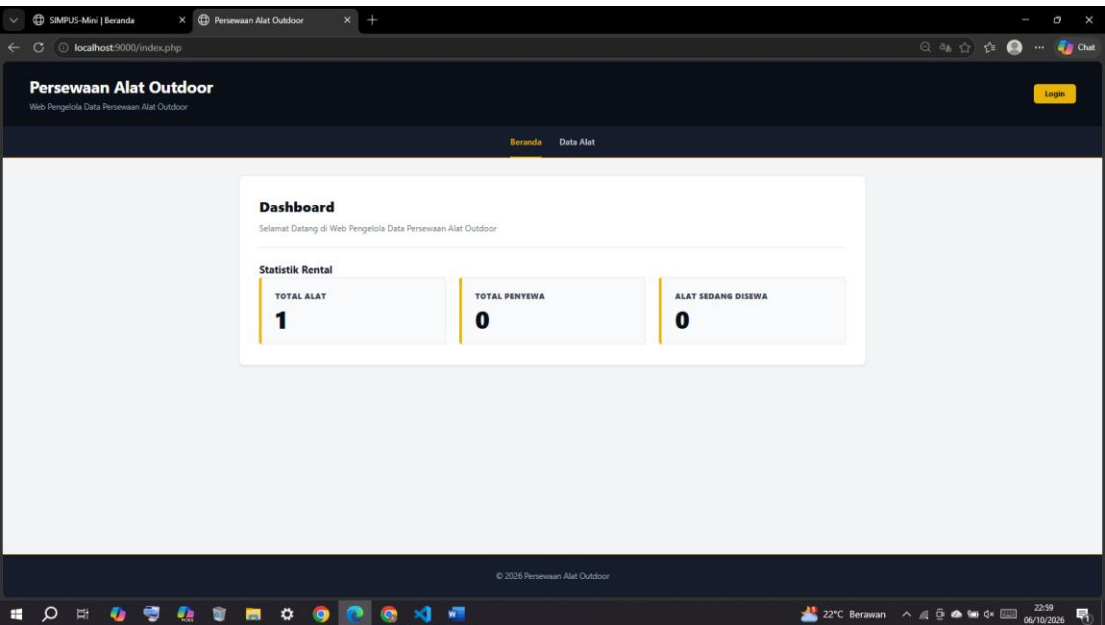
Mata Kuliah : Pemrograman Web
Program Studi : D4 – Sistem Informasi Bisnis
Semester : 3

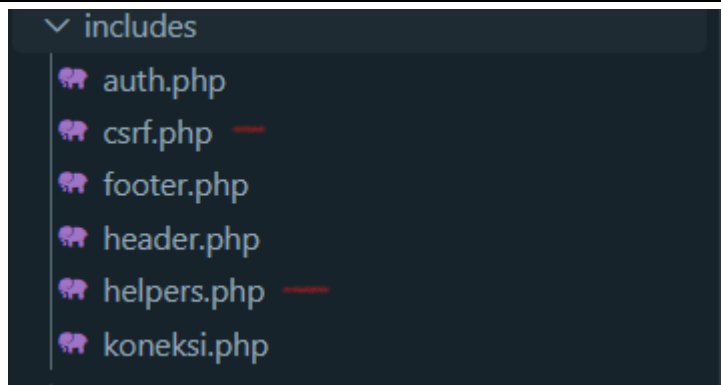
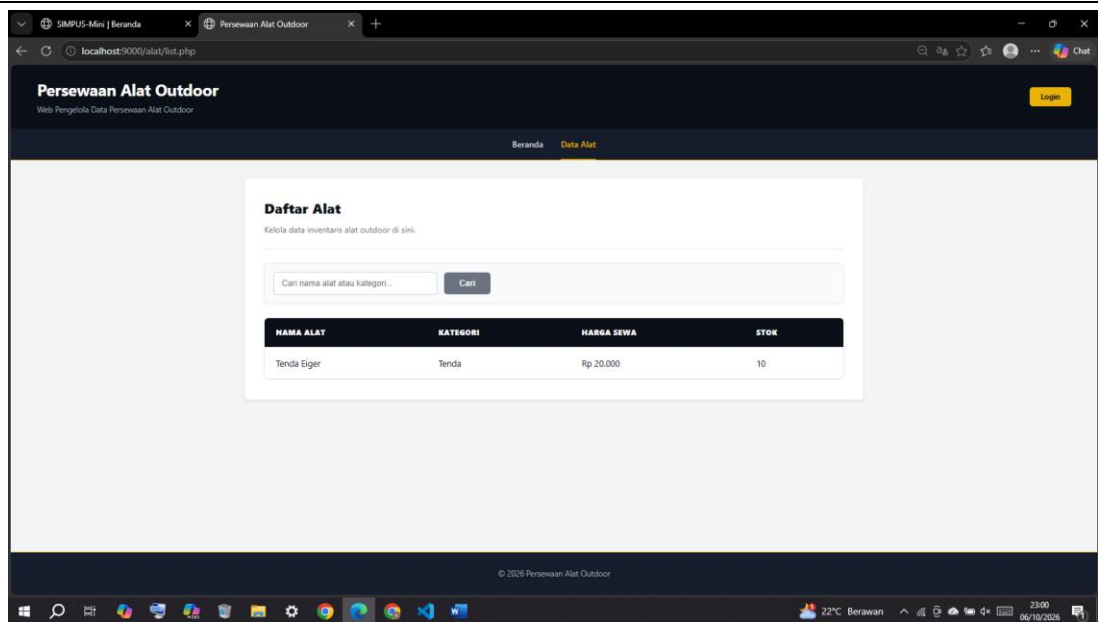
Kelas : SIB-2A
NIM : 254107060009
Nama : Muhammad Zasky Aryo Mahadani
Jobsheet Ke- : 11

Laporan Jobsheet

Pengimplementasian Terhadap Web persewaan alat outdoor

Berikut merupakan langkah-langkah pengimplementasian prinsip keamanan web dasar (XSS, CSRF, dan Session Fixation) pada aplikasi Web Persewaan Alat Outdoor beserta bukti penerapannya

No	Jawaban/Deskripsi
-	



Uji Coba

Pada tahap ini akan dilakukan percobaan pengujian fitur keamanan web yang mencakup proteksi CSRF, proteksi XSS, serta urutan autentikasi (guard order) pada aplikasi Web Persewaan Alat Outdoor.

No	Jawaban/Deskripsi																				
1	Pengujian CSRF (Cross-Site Request Forgery) Pengujian proteksi CSRF dilakukan dengan mengirimkan request POST ke proses_tambah.php menggunakan cookie sesi login aktif tanpa menyertakan csrf_token. Server secara otomatis menolak permintaan dan mengembalikan respon HTTP 403 Forbidden (Token CSRF tidak valid atau kedaluwarsa), yang membuktikan bahwa proteksi CSRF berhasil bekerja dengan baik. <pre>PS C:\POLITEKNIK NEGERI MALANG\SEMESTER-3\PEMROGRAMAN WEB\JOBSHEET-11\jobsheet-11_Persewaan Alat> curl.exe -i -b "PHPSESSID=ursitsfoqiaj62u7sic3cfb7e1" -X POST http://localhost:9000/alat/proses_tambah.php -d "nama_alat=Tenda Test&kategori=Tenda&tarif=50000&stok=5" HTTP/1.1 403 Forbidden Host: localhost:9000 Date: Tue, 06 Oct 2026 16:28:52 GMT Connection: close X-Powered-By: PHP/8.3.33 Expires: Thu, 19 Nov 1981 08:52:00 GMT Cache-Control: no-store, no-cache, must-revalidate Pragma: no-cache Content-type: text/html; charset=UTF-8 403 Forbidden: Token CSRF tidak valid atau kedaluwarsa. PS C:\POLITEKNIK NEGERI MALANG\SEMESTER-3\PEMROGRAMAN WEB\JOBSHEET-11\jobsheet-11_Persewaan Alat></pre>																				
2	Pengujian proteksi XSS dilakukan dengan menginputkan skrip JavaScript berbahaya <code><script>alert(1)</script></code> pada kolom Nama Alat. Saat data disimpan dan ditampilkan pada tabel Data Alat, skrip dirender secara aman sebagai string teks biasa berkat penerapan fungsi sanitasi <code>e()</code>, sehingga browser tidak mengeksekusi skrip tersebut. <table><tr><th>NAMA ALAT</th><th>KATEGORI</th><th>HARGA SEWA</th><th>STOK</th><th>AKSI</th></tr><tr><td><code><script>alert(1)</script></code></td><td>Tenda</td><td>Rp 200.000</td><td>5</td><td><button>Edit</button> <button>Hapus</button></td></tr><tr><td>Carrier Eiger</td><td>Carrier</td><td>Rp 200.000</td><td>5</td><td><button>Edit</button> <button>Hapus</button></td></tr><tr><td>Tenda Eiger</td><td>Tenda</td><td>Rp 20.000</td><td>10</td><td><button>Edit</button> <button>Hapus</button></td></tr></table>	NAMA ALAT	KATEGORI	HARGA SEWA	STOK	AKSI	<code><script>alert(1)</script></code>	Tenda	Rp 200.000	5	<button>Edit</button> <button>Hapus</button>	Carrier Eiger	Carrier	Rp 200.000	5	<button>Edit</button> <button>Hapus</button>	Tenda Eiger	Tenda	Rp 20.000	10	<button>Edit</button> <button>Hapus</button>
NAMA ALAT	KATEGORI	HARGA SEWA	STOK	AKSI																	
<code><script>alert(1)</script></code>	Tenda	Rp 200.000	5	<button>Edit</button> <button>Hapus</button>																	
Carrier Eiger	Carrier	Rp 200.000	5	<button>Edit</button> <button>Hapus</button>																	
Tenda Eiger	Tenda	Rp 20.000	10	<button>Edit</button> <button>Hapus</button>																	

2	Pengujian urutan keamanan (Guard Order) dilakukan dengan mengirimkan permintaan POST ke proses_tambah.php tanpa sesi login. Server merespon dengan HTTP 302 Found dan langsung mengarahkan pengguna ke halaman auth/login.php, membuktikan bahwa proteksi autentikasi dieksekusi lebih dulu sebelum sistem memproses verifikasi CSRF. <pre>PS C:\POLITEKNIK NEGERI MALANG\SEMESTER-3\PEMROGRAMAN WEB\JOBSHEET-11\jobsheet-11 Persewaan Alat> curl.exe -i -X POST http://localhost:9000/alat/proses_tambah.php -d "nama_alat=Tenda Test&kategori=Tenda&tarif=50000&stok=5" HTTP/1.1 302 Found Host: localhost:9000 Date: Tue, 06 Oct 2026 16:18:12 GMT Connection: close X-Powered-By: PHP/8.3.33 Set-Cookie: PHPSESSID=mr6dtffpeqpj7bf3f6lmt637f8; path=/ Expires: Thu, 19 Nov 1981 08:52:00 GMT Cache-Control: no-store, no-cache, must-revalidate Pragma: no-cache Location: ../auth/login.php Content-type: text/html; charset=UTF-8</pre>
---	--